

OpenZeppelin
Security Audit: Sample DEX

[C-01] Missing access control on admin setter

Description

The setFeeRecipient function in contracts/DEX.sol:88 has no onlyOwner guard. Any caller can redirect the protocol fee stream.

Recommendation

Add an onlyOwner modifier to setFeeRecipient.

[H-01] Integer overflow in fee calculation

Description

The fee calc in contracts/DEX.sol:200 multiplies unchecked uints.

Recommendation

Use Solidity 0.8+ checked arithmetic.

[M-01] Incorrect event emission order

Description

Events in contracts/DEX.sol:300 emit before state is updated.

Recommendation

Move the emit to after the state update.

[L-01] Missing zero-address check on token setter

Description

The setToken function in contracts/DEX.sol:400 lacks a zero check.

Recommendation

Add require(newToken != address(0)) guard.

[N-01] Stylistic NatSpec inconsistency in interfaces

Description

Interface files in contracts/interfaces/ mix NatSpec conventions.

Recommendation

Standardise on the @notice / @dev / @param ordering.

[I-01] Minor gas-savings opportunity in transfer

Description

The transfer function in contracts/Token.sol:100 uses a redundant storage read that can be folded into the existing balance update.

Recommendation

Combine the balance read with the subsequent update.